

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA KHOA HỌC VÀ KỸ THUẬT THÔNG TIN



BÀI TẬP THỰC HÀNH 6A (BUỔI 10)
QUẢN LÝ RỦI RO AN NINH
THÔNG TIN

Mã Môn: IE105
Tên Môn: Nhập Môn Đảm Bảo và An Ninh Thông Tin
Lớp: IE105.F22.LT.CNTT
Giảng Viên: ThS. Tô Nguyễn Nhật Quang
Sinh Viên: Đinh Xuân Sâm
Mã Sinh Viên: 25410291

Ngày 19 Tháng 05 Năm 2026

BÀI TẬP THỰC HÀNH 6A: QUẢN LÝ RỦI RO AN NINH THÔNG TIN

MỤC TIÊU BÀI THỰC HÀNH

Sau khi hoàn thành bài thực hành, sinh viên có thể:

1. Hiểu được khái niệm **rủi ro an ninh thông tin**.
2. Nhận diện **tài sản thông tin (Information Assets)**.
3. Xác định **mối đe dọa (Threats)** và **lỗ hổng (Vulnerabilities)**.
4. Đánh giá **mức độ rủi ro** dựa trên *Khả năng xảy ra* và *Mức độ ảnh hưởng*.
5. Đề xuất **biện pháp xử lý rủi ro** phù hợp.
6. Trình bày báo cáo theo **quy trình quản lý rủi ro cơ bản**.

KIẾN THỨC NỀN (SINH VIÊN TỰ TÌM HIỂU)

Sinh viên cần nắm các khái niệm sau:

- Asset (Tài sản)
- Threat (Mối đe dọa)
- Vulnerability (Lỗ hổng)
- Risk (Rủi ro)
- Risk Assessment (Đánh giá rủi ro)
- Risk Treatment (Xử lý rủi ro)

BỐI CẢNH ĐƯỢC CHỌN

Sinh viên CHỌN 01 trong 3 bối cảnh sau (ghi rõ đã chọn bối cảnh nào):

Bối cảnh 1

Máy tính cá nhân của sinh viên dùng cho:

- Học tập
- Email
- Lưu tài liệu cá nhân

Bối cảnh 2

Mạng Wi-Fi gia đình dùng cho:

- Nhiều thiết bị
- Học tập / làm việc online

Bối cảnh 3

Điện thoại thông minh của sinh viên dùng cho:

- Mạng xã hội
- Ngân hàng / ví điện tử
- Email

Không tự tạo bối cảnh khác.

TÓM TẮT & CẤU TRÚC BÁO CÁO

Bối cảnh được chọn là **Bối cảnh 3**:

- Điện thoại thông minh của sinh viên dùng cho mạng xã hội, ngân hàng/ví điện tử và email.
- Bối cảnh này được chọn vì điện thoại thông minh hiện đại tập trung nhiều loại tài sản thông tin có giá trị khác nhau trong một thiết bị duy nhất, đồng thời phản ánh thói quen sử dụng thực tế của sinh viên.

Báo cáo được tổ chức theo 6 phần theo quy trình quản lý rủi ro:

- **Phần 1:** Xác Định Tài Sản: Liệt kê và đánh giá giá trị 6 tài sản thông tin.
- **Phần 2:** Xác Định Mối Đe Dọa: Xác định 13 mối đe dọa (≥ 2 mỗi tài sản).
- **Phần 3:** Xác Định Lỗ Hổng: Phân tích lỗ hổng tạo điều kiện cho từng mối đe dọa.
- **Phần 4:** Đánh Giá Rủi Ro: Tính Mức Độ Rủi Ro = Khả Năng Xảy Ra $\times$ Mức Độ Ảnh Hưởng và phân loại.
- **Phần 5:** Xử Lý Rủi Ro: Chọn chiến lược và đề xuất biện pháp cụ thể.
- **Phần 6:** Nhận Xét & Tự Đánh Giá: Phân tích tổng hợp và rút kinh nghiệm.

Mỗi phần sẽ được trình bày trong mỗi chương riêng biệt trong báo cáo.

LỜI NÓI ĐẦU

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do.

LỜI CẢM ƠN

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do.

Giảng Viên

Mục Lục

Mục Lục	vi
Danh Sách Bảng	vii
Danh Sách Hình Ảnh	viii
Danh Sách Mã Nguồn	ix
Bảng Viết Tắt	x
1. PHẦN 1. XÁC ĐỊNH TÀI SẢN (ASSET IDENTIFICATION)	1
1.1. Bối Cảnh Được Chọn	1
1.2. Bước 1 & 2. Danh Sách Tài Sản Thông Tin	1
1.3. Nhận Xét Chung	2
2. PHẦN 2. XÁC ĐỊNH MỐI ĐE DỌA (THREAT IDENTIFICATION)	3
2.1. Bước 3. Mối Đe Dọa Theo Từng Tài Sản	3
2.2. Tổng Hợp Các Nhóm Mối Đe Dọa	4
3. PHẦN 3. XÁC ĐỊNH LỖ HỔNG (VULNERABILITY IDENTIFICATION)	6
3.1. Bước 4. Phân Tích Lỗ Hổng Theo Mối Đe Dọa	6
3.2. Tổng Hợp Về Lỗ Hổng	7
4. PHẦN 4 — ĐÁNH GIÁ RỦI RO (RISK ASSESSMENT)	8
4.1. Bước 5 & 6 — Ma Trận Đánh Giá Rủi Ro	8
4.2. Bước 7 — Phân Loại Rủi Ro	9
5. PHẦN 5. XỬ LÝ RỦI RO (RISK TREATMENT)	11
5.1. Bước 8. Chiến Lược Xử Lý Rủi Ro	11
5.2. Bước 9. Đề Xuất Biện Pháp Cụ Thể	12
6. PHẦN 6. NHẬN XÉT & TỰ ĐÁNH GIÁ	14
6.1. Bước 10. Trả Lời Câu Hỏi	14
A Thông Tin Về Báo Cáo Đây	16
A.1 Mã Nguồn Báo Cáo	16
A.2 Mã Nguồn Nội Dung Chính	16
Tài Liệu Tham Khảo	17

DANH SÁCH BẢNG

Bảng 1	Danh Sách Tài Sản	1
Bảng 2	Mối Đe Dọa Đối Với Các Tài Sản	3
Bảng 3	Lỗ Hổng	6
Bảng 4	Đánh Giá Rủi Ro	9
Bảng 5	Phân Loại Rủi Ro	9
Bảng 6	Kế Hoạch Xử Lý Rủi Ro	12

DANH SÁCH HÌNH ẢNH

DANH SÁCH MÃ NGUỒN

BẢNG VIẾT TẮT

Viết Tắt	Nghĩa Đầy Đủ
AES	Advanced Encryption Standard
CCMP	Counter Mode with Cipher Block Chaining Message Authentication Code Protocol
DHCP	Dynamic Host Configuration Protocol
DNS	Domain Name System
FTPS	File Transfer Protocol Secure
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
KRACK	Key Reinstallation Attacks
MAC	Media Access Control
SSH	Secure Shell
SSID	Service Set Identifier
TKIP	Temporal Key Integrity Protocol
VPN	Virtual Private Network
WEP	Wired Equivalent Privacy
Wi-Fi	Wireless Fidelity
WPA	Wi-Fi Protected Access
WPA2	Wi-Fi Protected Access 2
WPA3	Wi-Fi Protected Access 3

Bảng Viết Tắt

CHƯƠNG 1.

PHẦN 1. XÁC ĐỊNH TÀI SẢN (ASSET IDENTIFICATION)

1.1. Bối Cảnh Được Chọn

Sinh viên chọn **Bối cảnh 3**: Điện thoại thông minh của sinh viên dùng cho:

- Mạng xã hội (Facebook, Instagram, TikTok, Zalo)
- Ngân hàng / ví điện tử (Internet Banking, MoMo, ViettelPay)
- Email (Gmail)

Điện thoại thông minh ngày nay không chỉ là thiết bị liên lạc mà còn là kho lưu trữ tập trung nhiều loại dữ liệu nhạy cảm — từ thông tin tài chính, danh tính cá nhân đến lịch sử giao tiếp. Vì vậy đây là bối cảnh phù hợp để thực hành nhận diện và phân tích rủi ro an ninh thông tin.

1.2. Bước 1 & 2. Danh Sách Tài Sản Thông Tin

Dưới đây là 6 tài sản thông tin được xác định trong bối cảnh sử dụng điện thoại thông minh, kèm mô tả ngắn gọn và đánh giá giá trị.

stt	Tài Sản	Mô Tả	Giá Trị
1	Tài khoản mạng xã hội (Facebook, Instagram, TikTok, Zalo)	Chứa thông tin cá nhân, danh sách bạn bè, lịch sử hội thoại, ảnh/video cá nhân. Bị xâm phạm có thể dẫn đến mạo danh, lừa đảo người thân hoặc tống tiền.	Cao
2	Tài khoản ngân hàng / ví điện tử (Internet Banking, MoMo, ViettelPay)	Liên kết trực tiếp đến tài sản tài chính. Bị mất quyền kiểm soát đồng nghĩa với nguy cơ mất tiền ngay lập tức và khó thu hồi.	Cao
3	Email cá nhân (Gmail)	Là “chìa khóa chủ” — dùng để khôi phục mật khẩu hầu hết các dịch vụ khác. Nếu bị chiếm, kẻ tấn công có thể kiểm soát toàn bộ danh tính số của người dùng.	Cao
4	Danh bạ liên lạc	Chứa số điện thoại, tên và mối quan hệ của người thân, bạn bè, đồng nghiệp. Dữ liệu này có giá trị với kẻ lừa đảo (social engineering) hoặc spammer.	Trung Bình

stt	Tài Sản	Mô Tả	Giá Trị
5	Ảnh và video cá nhân (Bộ nhớ trong / thư viện ảnh)	Lưu trữ kỷ niệm cá nhân, ảnh nhạy cảm, tài liệu chụp bằng camera (CMND, thẻ ngân hàng, hợp đồng). Rò rỉ có thể gây tổn hại danh dự hoặc tạo điều kiện giả mạo giấy tờ.	Trung Bình
6	Lịch sử trò chuyện (SMS, Messenger, Zalo)	Ghi lại các cuộc hội thoại riêng tư, có thể chứa thông tin nhạy cảm như mã OTP, địa chỉ, kế hoạch cá nhân. Bị rò rỉ ảnh hưởng đến quyền riêng tư và có thể bị dùng để ép buộc.	Trung Bình

Bảng 1: Danh Sách Tài Sản

1.3. Nhận Xét Chung

Trong 6 tài sản trên, ba tài sản đầu (tài khoản mạng xã hội, tài khoản tài chính, và email) được đánh giá ở mức **Cao** vì chúng gắn trực tiếp đến danh tính, tài sản và khả năng phục hồi các tài khoản khác.

Ba tài sản còn lại mang giá trị **Trung Bình** — không gây thiệt hại tài chính trực tiếp nhưng vẫn ảnh hưởng nghiêm trọng đến quyền riêng tư nếu bị xâm phạm. Không có tài sản nào được xếp loại **Thấp** vì tất cả đều chứa thông tin cá nhân có thể bị lợi dụng.

CHƯƠNG 2.

PHẦN 2. XÁC ĐỊNH MỐI ĐE DỌA (THREAT IDENTIFICATION)

Với **mỗi tài sản**, liệt kê ít nhất **2 mối đe dọa** có thể xảy ra.

Gợi ý (không bắt buộc):

- Mất cắp
- Truy cập trái phép
- Mã độc
- Lộ mật khẩu
- Lỗi người dùng

2.1. Bước 3. Mối Đe Dọa Theo Từng Tài Sản

Với **mỗi tài sản** đã xác định ở Phần 1, dưới đây ta có thể liệt kê các **mối đe dọa** có thể xảy ra kèm **mô tả cụ thể về cơ chế và hậu quả**.

Tài Sản	Mối Đe Dọa	Mô Tả
TS1 Tài khoản mạng xã hội (Facebook, Instagram, TikTok, Zalo)	1.1. Truy cập trái phép	Kẻ tấn công đánh cắp thông tin đăng nhập qua phishing hoặc brute-force để chiếm quyền tài khoản, sau đó mạo danh nạn nhân để lừa đảo người thân hoặc phát tán nội dung độc hại.
	1.2. Lộ thông tin cá nhân qua cài đặt quyền riêng tư sai	Người dùng để hồ sơ và bài đăng ở chế độ công khai, vô tình chia sẻ thông tin địa điểm, thói quen sinh hoạt, số điện thoại — tạo nguyên liệu cho tấn công social engineering.
	1.3. Cài đặt ứng dụng giả mạo	Ứng dụng giả mạo Facebook/Zalo được phát tán ngoài các kho chính thức (Apple Store/Play Store). Sau khi cài, ứng dụng có thể thu thập thông tin đăng nhập hoặc đọc nội dung hội thoại trong nền.
TS2 Tài khoản ngân hàng / ví điện tử (Internet Banking, MoMo, ViettelPay)	2.1. Tấn công Phishing / Smishing	Nạn nhân nhận được tin nhắn SMS hoặc email giả mạo ngân hàng, dẫn đến trang web nhái và bị thu thập tên đăng nhập, mật khẩu và mã OTP. Sau đó, kẻ tấn công dùng thông tin này để chuyển tiền.
	2.2. Đánh cắp OTP qua SIM Swapping	Kẻ tấn công liên hệ nhà mạng giả mạo chủ thuê bao để chuyển số điện thoại sang SIM mới. Từ đó nhận được tất cả OTP gửi về số đó và vượt qua xác thực 2 bước của ứng dụng ngân hàng.

Tài Sản	Mối Đe Dọa	Mô Tả
	2.3. Mã độc Trojan trên điện thoại	Phần mềm độc hại ngụy trang thành ứng dụng hữu ích (đèn pin, game). Sau khi cài, Trojan ghi lại các thao tác nhập liệu (keylogger) hoặc chụp màn hình khi người dùng mở ứng dụng ngân hàng.
TS3 Email cá nhân (Gmail)	3.1. Tấn công Credential Stuffing	Kẻ tấn công dùng danh sách tên đăng nhập/mật khẩu bị rò rỉ từ các dịch vụ khác để thử đăng nhập vào Gmail. Nếu người dùng tái sử dụng mật khẩu, tài khoản sẽ bị chiếm.
	3.2. Truy cập trái phép từ thiết bị bị mất / bị đánh cắp	Nếu điện thoại không có mã khóa màn hình hoặc màn hình không tự khóa sau thời gian ngắn, người khác có điện thoại trong tay có thể truy cập trực tiếp vào Gmail đang đăng nhập.
TS4 Danh bạ liên lạc	4.1. Ứng dụng yêu cầu quyền truy cập danh bạ không hợp lý	Nhiều ứng dụng (game, tiện ích) yêu cầu quyền đọc danh bạ để thu thập và bán dữ liệu liên lạc cho bên thứ ba, hoặc dùng cho mục đích spam và lừa đảo có chủ đích.
	4.2. Đồng bộ lên dịch vụ đám mây không bảo mật	Danh bạ tự động đồng bộ lên tài khoản cloud (Google, iCloud). Nếu tài khoản online bị xâm phạm hoặc dịch vụ bị rò rỉ dữ liệu, toàn bộ danh bạ có thể bị lộ ra ngoài.
TS5 Ảnh và video cá nhân (Thư viện ảnh)	5.1. Rò rỉ qua sao lưu đám mây không được bảo vệ đúng cách	Tính năng sao lưu tự động (Google Photos, iCloud) tải ảnh lên với mức bảo mật phụ thuộc vào mật khẩu tài khoản. Nếu tài khoản bị chiếm, kẻ tấn công có thể tải xuống toàn bộ thư viện ảnh.
	5.2. Khai thác ứng dụng chỉnh sửa ảnh độc hại	Ứng dụng chỉnh sửa ảnh miễn phí từ nguồn không chính thống yêu cầu quyền đọc/ghi thư viện ảnh. Thực tế ứng dụng âm thầm tải ảnh lên máy chủ của kẻ tấn công.
TS6 Lịch sử trò chuyện (SMS, Messenger, Zalo)	6.1. Chặn bắt tin nhắn SMS (SMS Interception)	Mã OTP và tin nhắn nhạy cảm gửi qua SMS có thể bị chặn nếu kẻ tấn công kiểm soát được mạng di động (IMSI catcher) hoặc đã thực hiện SIM Swapping thành công.
	6.2. Đọc lịch sử chat qua phần mềm gián điệp (Spyware)	Spyware được cài lên điện thoại (thường qua quyền truy cập vật lý) có thể đọc và gửi lên lịch sử hội thoại trên Messenger, Zalo về máy chủ của kẻ theo dõi mà nạn nhân không hay biết.

Bảng 2: Mối Đe Dọa Đối Với Các Tài Sản

2.2. Tổng Hợp Các Nhóm Mối Đe Dọa

Nhìn chung, các mối đe dọa có thể phân nhóm theo tính chất như sau:

- **Tấn công từ xa** (phishing, smishing, credential stuffing, SIM swapping): Không cần tiếp xúc vật lý với thiết bị, thường nhắm vào tài khoản tài chính và email có giá trị cao.

- **Phần mềm độc hại** (Trojan, fake app, spyware): Khai thác thói quen cài ứng dụng từ nguồn ngoài kho chính thức hoặc click vào đường link lạ.
- **Lỗi cấu hình / thói quen người dùng** (quyền riêng tư sai, không khóa màn hình, tái sử dụng mật khẩu): Tạo cơ hội cho cả tấn công từ xa lẫn tấn công vật lý.
- **Rò rỉ qua bên thứ ba** (ứng dụng lấy quyền danh bạ/ảnh, dịch vụ đám mây): Thường bị bỏ qua nhưng có tần suất xảy ra cao do người dùng ít chú ý đến quyền ứng dụng.

CHƯƠNG 3.

PHẦN 3. XÁC ĐỊNH LỖ HỔNG (VULNERABILITY IDENTIFICATION)

Phân tích lỗ hổng hiện có khiến mối đe dọa dễ xảy ra.

Ví dụ:

- Không khóa màn hình
- Mật khẩu yếu
- Không cập nhật hệ điều hành
- Dùng Wi-Fi công cộng

3.1. Bước 4. Phân Tích Lỗ Hổng Theo Mối Đe Dọa

Với mỗi mối đe dọa đã xác định ở Phần 2, dưới đây phân tích lỗ hổng hiện có trong thói quen sử dụng điện thoại thông minh khiến mối đe dọa đó dễ xảy ra hơn.

Mã	Mối Đe Dọa	Lỗ Hổng Liên Quan
T1	Chiếm đoạt tài khoản (TS1)	• Không bật xác thực 2 bước (2FA). • Mật khẩu ngắn, đơn giản hoặc tái sử dụng trên nhiều dịch vụ.
T2	Rò rỉ thông tin qua cài đặt quyền riêng tư (TS1)	• Cài đặt mặc định của ứng dụng mạng xã hội thường là “công khai”. • Người dùng không kiểm tra lại sau khi cập nhật ứng dụng
T3	Ứng dụng giả mạo (TS1)	• Thói quen tải app từ nguồn ngoài kho chính thức (sideloading/jailbreak). • Thiếu kiểm tra nhà phát triển và đánh giá ứng dụng
T4	Tấn công lừa đảo (TS2)	• Nhấp vào đường link trong SMS/email mà không kiểm tra URL. • Thiếu nhận thức về dấu hiệu trang web giả mạo
T5	SIM Swapping (TS2)	• Thông tin cá nhân (tên, ngày sinh, CMND) bị lộ trên mạng xã hội. • Phụ thuộc hoàn toàn vào SMS OTP.
T6	Trojan trên điện thoại (TS2)	• Cài ứng dụng từ kho bên thứ ba hoặc file APK chia sẻ qua Zalo/Telegram. • Không bật tính năng Play Protect
T7	Tấn công Credential Stuffing (TS3)	• Tái sử dụng cùng một mật khẩu cho nhiều dịch vụ. • Không bật cảnh báo đăng nhập từ thiết bị lạ
T8	Truy cập thiết bị bị mất (TS3)	• Không đặt mã PIN/mật khẩu màn hình. • Thời gian tự khóa màn hình quá dài (> 5 phút) hoặc tắt hoàn toàn

Mã	Mối Đe Dọa	Lỗ Hổng Liên Quan
T9	Ứng dụng yêu cầu quyền truy cập danh bạ (TS4)	- Cấp quyền tùy tiện khi ứng dụng yêu cầu mà không đọc mục đích. - Không rà soát lại danh sách quyền đã cấp.
T10	Đồng bộ đám mây không an toàn (TS4)	- Mật khẩu tài khoản Google/iCloud yếu. - Không bật 2FA cho tài khoản cloud.
T11	Rò rỉ thông tin qua sao lưu đám mây (TS5)	- Sao lưu tự động bật mặc định mà người dùng không kiểm tra. - Ảnh quan trọng như là thiết kế sản phẩm độc quyền, lưu chung với ảnh thông thường không phân loại.
T12	Ứng dụng chỉnh sửa ảnh độc hại (TS5)	- Cấp quyền đọc/ghi thư viện ảnh cho ứng dụng không đáng tin cậy. - Tải ứng dụng chỉnh sửa ảnh miễn phí từ nguồn không chính thống.
T13	Đánh cắp tin nhắn (TS6)	Phụ thuộc hoàn toàn vào SMS để nhận OTP thay vì dùng ứng dụng xác thực (Authenticator App).
T14	Phần mềm gián điệp (TS6)	- Cho phép người khác mượn điện thoại không có giám sát. - Không bật App Lock cho ứng dụng nhạy cảm.

Bảng 3: Lỗ Hổng

3.2. Tổng Hợp Về Lỗ Hổng

Phân tích cho thấy hầu hết các lỗ hổng đều bắt nguồn từ **bản thân người dùng** chứ không phải từ lỗi kỹ thuật của hệ thống.

Ba nhóm lỗ hổng nổi bật nhất:

- **Xác thực yếu:** Không dùng 2FA, mật khẩu đơn giản, tái sử dụng mật khẩu — xuất hiện trong 5/14 mối đe dọa.
- **Cài đặt ứng dụng thiếu cẩn thận:** Sideload APK/Jailbreak, không kiểm tra quyền — xuất hiện trong 4/14 mối đe dọa.
- **Thiếu cấu hình bảo vệ thiết bị:** Không có màn hình khóa, thời gian tự khóa dài — ảnh hưởng trực tiếp đến truy cập vật lý trái phép.

CHƯƠNG 4.

PHẦN 4 — ĐÁNH GIÁ RỦI RO (RISK ASSESSMENT)

Bước 5: Đánh giá **Khả năng xảy ra (Likelihood)** và **Mức độ ảnh hưởng (Impact)** theo thang điểm:

- Thấp (1)
- Trung bình (2)
- Cao (3)

Bước 6: Tính **Mức độ rủi ro** = Likelihood × Impact.

Bảng 4: Đánh giá rủi ro

Tài sản	Mối đe dọa	Likelihood	Impact	Risk Level
TS1	T1	1	1	1

Bước 7: Phân loại rủi ro:

- 1–2: Thấp
- 3–4: Trung bình
- 6–9: Cao

4.1. Bước 5 & 6 — Ma Trận Đánh Giá Rủi Ro

Mỗi mối đe dọa được đánh giá theo thang điểm:

- **Khả năng xảy ra (Likelihood):** 1 / 2 / 3
 - 1: Rất khó xảy ra hoặc không có nhu cầu thực hiện.
 - 2: Có thể xảy ra hoặc có nhu cầu thực hiện ở mức độ nhất định.
 - 3: Dễ dàng xảy ra hoặc có chủ đích thực hiện.
- **Mức độ ảnh hưởng (Impact):** 1 / 2 / 3
 - 1: Ảnh hưởng không đáng kể, có thể khắc phục dễ dàng.
 - 2: Ảnh hưởng ở mức độ nhất định, có thể khắc phục.
 - 3: Ảnh hưởng nghiêm trọng, khó khắc phục hoặc không thể khắc phục.
- **Mức độ rủi ro (Risk Level)** = Likelihood × Impact
 - Phản ánh tương quan tuyến tính giữa Likelihood và Impact.

Mã	Tài Sản	Mối Đe Dọa	Likelihood	Impact	Risk Level
T1	TS1. Mạng xã hội	Chiếm đoạt tài khoản	2	3	6
T2	TS1. Mạng xã hội	Lộ thông tin qua privacy sai	3	2	6
T3	TS1. Mạng xã hội	Cài đặt Fake App	2	3	6
T4	TS2. Ngân hàng/Ví	Tấn công lừa đảo	3	3	9
T5	TS2. Ngân hàng/Ví	SIM Swapping	1	3	3
T6	TS2. Ngân hàng/Ví	Trojan trên điện thoại	2	3	6
T7	TS3. Email	Credential Stuffing	2	3	6
T8	TS3. Email	Truy cập thiết bị bị mất	2	3	6
T9	TS4. Danh bạ	App yêu cầu quyền danh bạ	3	2	6
T10	TS4. Danh bạ	Đồng bộ cloud không bảo mật	2	2	4
T11	TS5. Ảnh/Video	Rò rỉ qua cloud backup	2	2	4
T12	TS5. Ảnh/Video	App chỉnh sửa ảnh độc hại	2	2	4
T13	TS6. Lịch sử chat	Đánh cắp tin nhắn	1	3	3
T14	TS6. Lịch sử chat	Phần mềm gián điệp	1	3	3

Bảng 4: Đánh Giá Rủi Ro

4.2. Bước 7 — Phân Loại Rủi Ro

- Risk Level 1–2: **Thấp**
 - Khó hoặc không có nhu cầu thực hiện, hoặc ảnh hưởng không đáng kể.
- Risk Level 3–4: **Trung Bình**
 - Có thể thực hiện và ảnh hưởng ở mức độ nhất định.
- Risk Level 6–9: **Cao**
 - Có chủ đích thực hiện rõ ràng và ảnh hưởng nghiêm trọng.

Trong 14 rủi ro được đánh giá:

- 8 rủi ro **Cao** và 6 rủi ro **Trung Bình**.
- Không có rủi ro nào ở mức **Thấp** — phản ánh thực tế rằng điện thoại thông minh là mục tiêu tấn công hấp dẫn do tập trung nhiều loại tài sản có giá trị.
- Rủi ro **T4** (Phishing/Smishing) đạt mức cao nhất (9/9), là một trong những hình thức tấn công phổ biến và nguy hiểm nhất hiện nay đặc biệt thiết bị di động được xem là phổ cập.

Mã	Mối Đe Dọa	Likelihood	Impact	Risk Level	Phân Loại
T1	Chiếm đoạt tài khoản	2	3	6	Cao
T2	Lộ thông tin qua privacy sai	3	2	6	Cao
T3	Cài đặt Fake App	2	3	6	Cao
T4	Tấn công lừa đảo (Phishing/Smishing)	3	3	9	Cao
T5	SIM Swapping	1	3	3	Trung Bình
T6	Trojan trên điện thoại	2	3	6	Cao

Mã	Mối Đe Dọa	Likelihood	Impact	Risk Level	Phân Loại
T7	Credential Stuffing	2	3	6	Cao
T8	Truy cập thiết bị bị mất	2	3	6	Cao
T9	App yêu cầu quyền danh bạ	3	2	6	Cao
T10	Đồng bộ cloud không bảo mật	2	2	4	Trung Bình
T11	Rò rỉ qua cloud backup	2	2	4	Trung Bình
T12	App chỉnh sửa ảnh độc hại	2	2	4	Trung Bình
T13	Đánh cắp tin nhắn	1	3	3	Trung Bình
T14	Phần mềm gián điệp	1	3	3	Trung Bình

Bảng 5: Phân Loại Rủi Ro

CHƯƠNG 5.

PHẦN 5. XỬ LÝ RỦI RO (RISK TREATMENT)

Bước 8: Với mỗi rủi ro mức Trung bình hoặc Cao, chọn 1 chiến lược xử lý:

- Avoid (Tránh)
- Mitigate (Giảm)
- Transfer (Chuyển)
- Accept (Chấp nhận)

Bước 9: Đề xuất biện pháp cụ thể.

Bảng 5: Kế hoạch xử lý rủi ro

Rủi ro	Mức	Chiến lược	Biện pháp đề xuất
ABC			
DEF			

5.1. Bước 8. Chiến Lược Xử Lý Rủi Ro

Với tất cả 14 rủi ro đều ở mức Trung Bình hoặc Cao, mỗi rủi ro được gán một chiến lược xử lý và biện pháp cụ thể.

Chiến lược sử dụng:

- **Avoid** (Tránh):
 - Loại bỏ hoàn toàn hành vi dẫn đến rủi ro, không thể chấp nhận được.
- **Mitigate** (Giảm):
 - Giảm khả năng xảy ra hoặc mức độ ảnh hưởng vì khó lường, không thể loại bỏ hoàn toàn.
- **Transfer** (Chuyển):
 - Chuyển giao rủi ro cho bên thứ ba (bảo hiểm, dịch vụ bảo mật).
- **Accept** (Chấp nhận):
 - Chấp nhận rủi ro vì chi phí xử lý không tương xứng hoặc không có phương án hiệu quả.

5.2. Bước 9. Đề Xuất Biện Pháp Cụ Thể

Mã	Rủi Ro	Mức	Chiến Lược	Biện Pháp Đề Xuất
T1	Chiếm đoạt tài khoản	Cao	Mitigate	- Bật 2FA trên tất cả tài khoản online. - Dùng password manager để tạo và lưu mật khẩu mạnh, riêng biệt.
T2	Lộ thông tin qua privacy	Cao	Mitigate	- Rà soát cài đặt quyền riêng tư định kỳ. - Chuyển hồ sơ về chế độ “Chỉ bạn bè” hoặc tương tự.
T3	Ứng dụng giả mạo	Cao	Avoid	- Chỉ tải ứng dụng từ App Store / Google Play chính thống. - Không cài APK từ nguồn ngoài/bể khóa.
T4	Lừa đảo Phishing / Smishing	Cao	Mitigate	- Không nhấp link trong SMS/email/Zalo/Telegram. - Luôn truy cập trực tiếp trang web/app chính thống. - Kiểm tra URL/địa chỉ người gửi trước khi tương tác.
T5	SIM Swapping	TB	Mitigate	- Đăng ký bảo vệ SIM với nhà mạng (nếu có thể). - Dùng Authenticator App thay SMS OTP. - Hạn chế đăng thông tin cá nhân lên MXH.
T6	Trojan	Cao	Avoid	- Không cài APK ngoài kho chính thống. - Bật Google Play Protect hoặc tính năng tương tự trên iOS. - Không tải file từ Zalo/Telegram/Mạng xã hội chưa xác thực nguồn gốc.
T7	Credential Stuffing	Cao	Mitigate	- Dùng mật khẩu riêng biệt cho mỗi dịch vụ (password manager). - Bật cảnh báo đăng nhập bất thường trên Gmail/Google Account và các dịch vụ khác.
T8	Truy cập thiết bị bị mất	Cao	Mitigate	- Bật màn hình khóa PIN/Face ID/Vân tay. - Cài thời gian tự khóa ≤ 1 phút. - Bật Find My Device / Find My iPhone.
T9	App quyền danh bạ	Cao	Mitigate	- Từ chối quyền danh bạ với ứng dụng không cần thiết. - Rà soát lại quyền đã cấp trong Cài đặt hệ thống.
T10	Đồng bộ cloud không bảo mật	TB	Mitigate	- Bật 2FA cho tài khoản Google / iCloud và các dịch vụ khác. - Đổi mật khẩu thành chuỗi mạnh dài ≥ 12 ký tự, có số, ký tự đặc biệt.
T11	Rò rỉ cloud backup	TB	Mitigate	- Kiểm tra và giới hạn nội dung được sao lưu (nếu không cần thiết). - Lưu ảnh quan trọng trong album ẩn hoặc thư mục có mã khóa riêng (nếu có thể).

Mã	Rủi Ro	Mức	Chiến Lược	Biện Pháp Đề Xuất
T12	App chỉnh sửa ảnh độc hại	TB	Avoid	- Chỉ dùng ứng dụng chỉnh sửa ảnh uy tín từ kho chính thức. - Cấp quyền ảnh ở mức “Chọn ảnh” thay vì “Toàn bộ thư viện”.
T13	Đánh cắp tin nhắn	TB	Mitigate	Chuyển sang dùng Authenticator App (Google Authenticator, Microsoft Authenticator) cho tất cả dịch vụ hỗ trợ TOTP.
T14	Phần mềm gián điệp	TB	Mitigate	- Không cho mượn điện thoại không có giám sát, đặc biệt có chứa dữ liệu công việc. - Bật App Lock cho ứng dụng nhạy cảm. - Kiểm tra ứng dụng lạ định kỳ.

Bảng 6: Kế Hoạch Xử Lý Rủi Ro

PHẦN 6. NHẬN XÉT & TỰ ĐÁNH GIÁ

Bước 10: Sinh viên trả lời ngắn gọn (5–7 dòng mỗi câu):

1. Rủi ro nào nghiêm trọng nhất? Vì sao?
2. Nếu không áp dụng biện pháp, hậu quả có thể là gì?
3. Vai trò của người dùng trong quản lý rủi ro là gì?

6.1. Bước 10. Trả Lời Câu Hỏi

6.1.1. Câu 1. Rủi Ro Nào Nghiêm Trọng Nhất? Vì Sao?

Rủi ro nghiêm trọng nhất là **T4 — Phishing / Smishing** nhắm vào tài khoản ngân hàng và ví điện tử, với Risk Level = 9/9 (Likelihood 3, Impact 3). Đây là mức tối đa trong thang đánh giá.

Likelihood ở mức cao nhất vì lừa đảo qua SMS giả mạo ngân hàng đang xảy ra hàng ngày ở Việt Nam, rất dễ gặp và không đòi hỏi kỹ năng kỹ thuật cao từ phía kẻ tấn công.

Impact cũng ở mức tối đa vì nạn nhân tự cung cấp thông tin đăng nhập và OTP — kẻ tấn công có thể chuyển tiền ngay lập tức và gần như không thể thu hồi.

Đây là kịch bản gây thiệt hại tài chính trực tiếp, nhanh chóng và phổ biến nhất trong thực tế hiện nay.

6.1.2. Câu 2. Nếu Không Áp Dụng Biện Pháp, Hậu Quả Có Thể Là Gì?

Nếu không áp dụng bất kỳ biện pháp xử lý rủi ro nào, hậu quả sẽ leo thang theo chuỗi.

Trước tiên, tài khoản ngân hàng bị xâm phạm dẫn đến mất tiền trực tiếp và không thể hoàn lại.

Tiếp theo, email bị chiếm mang theo quyền khôi phục mật khẩu của hầu hết dịch vụ khác — kẻ tấn công từ đó chiếm quyền kiểm soát toàn bộ danh tính số.

Tài khoản mạng xã hội bị lợi dụng để phát tán lừa đảo đến người thân, gây thiệt hại cho cả cộng đồng xung quanh. Dài hạn, thông tin cá nhân bị rao bán trên dark web, làm nguyên liệu cho các cuộc tấn công tinh vi hơn trong tương lai. Một lỗ hổng không được vá có thể kéo theo hàng loạt rủi ro mới mà nạn nhân không hay biết.

6.1.3. Câu 3. Vai Trò Của Người Dùng Trong Quản Lý Rủi Ro Là Gì?

Người dùng vừa là **tuyến phòng thủ đầu tiên** vừa là **mắt xích yếu nhất** trong hệ thống an ninh thông tin. Hầu hết các lỗ hổng đều bắt nguồn từ thói quen hằng ngày hoặc không tuân thủ các biện pháp phòng chống rủi ro: mật khẩu yếu, cấp quyền ứng dụng thiếu cẩn thận, không bật 2FA, hay nhấp vào link không xác thực.

Công nghệ bảo mật — dù tinh vi đến đâu — chỉ phát huy hiệu quả khi người dùng sử dụng đúng cách và duy trì thói quen bảo mật nhất quán.

Vì vậy, vai trò của người dùng không chỉ là nạn nhân thụ động mà phải là người chủ động: thường xuyên cập nhật kiến thức về mối đe dọa mới, rà soát cài đặt bảo mật định kỳ, và xem an ninh thông tin là trách nhiệm cá nhân, không phải việc của riêng bộ phận IT hoặc bất kỳ một công cụ nào khác.

Thông Tin Về Báo Cáo Đây

A.1 Mã Nguồn Báo Cáo

- Miêu tả: Báo cáo này được xây dựng từ mã nguồn [Typst](#), với nội dung chính được chuẩn bị từ Markdown.
- Lưu trữ tại: nhánh [IE105-TH6A](#) của repo [sam-uit/typst-report-template](#)

A.2 Mã Nguồn Nội Dung Chính

- Miêu tả: Được chuẩn bị với Markdown, trong kho của [Obsidian](#).
- Lưu trữ tại: [uit/courses/IE105/assignments](#)

Tài Liệu Tham Khảo
